Notespace Backend Testing Report

Assessment date: 2026-10-23
Scope: Read-only backend, authentication, persistence, OTP, rules, and test-infrastructure assessment. No application source was changed, no credentials were used, and no external service was contacted.

Update — 2026-10-23: OTP bridge regression fix and verification

The Firebase Functions OTP bridge in `functions/index.js` was updated after the audit reproduced an upstream HTTP 503 being returned as HTTP 200. A regression suite was added at `functions/test/otpBridge.cjs`. It verifies that upstream HTTP 503 returns HTTP 503; other upstream HTTP failures, network errors, invalid JSON, and malformed response shapes return a generic HTTP 502; successful responses and valid OTP rejection responses retain their existing HTTP 200 body; and request validation remains intact. Error logging avoids upstream response bodies and exception details. The `.cjs` extension keeps Vitest from trying to collect the Node built-in test file.

Verification after the fix:

- `node --test functions/test/otpBridge.cjs` — **PASS**, 8/8.
- `npm test -- --run` — **PASS**, 21/21 across 3 test files.
- `npm run lint` — **PASS**.
- `node --check functions/index.js && node --check functions/test/otpBridge.cjs` — **PASS**.
- `git diff --check` — **PASS**.

The original mocked upstream-503 check failed before the fix because the handler returned HTTP 200 with a failure body. The regression test now passes after the fix. This was a historical, pre-fix failure and is not counted as a current failure. These are local automated/mocked checks, not live service verification. No Cloudflare Worker source was found; this fix and test apply to the Firebase Functions `otpBridge`. No deployment or Firebase configuration change was made. The production build passed in the earlier audit with a non-blocking large-JavaScript-bundle warning; it was **not rerun** after this fix.

Executive summary

The existing web test suite, targeted OTP bridge regression tests, lint, and current Node syntax checks pass. The bridge regression tests use mocked upstream responses; they do not verify a deployed function or live OTP provider. The earlier production build passed with a non-blocking large-JavaScript-bundle warning and was not rerun after the OTP fix.

This does **not** establish production backend readiness. The shipped note/folder data path inspected here uses browser `localStorage`; no Firestore or Firebase Storage access or rules were found. Firebase Authentication is used directly by the public login page, but the app-wide auth context also contains localStorage-backed account/session behavior. There is no configured Firebase Emulator Suite, no Cloudflare Worker source in the repository, and no safe production credentials or staging endpoints were supplied. Live authentication, OTP delivery, account isolation, and external persistence were therefore not tested.

The mocked HTTP status defect found in the original audit has been fixed and its regression test passes. The duplicate Tiptap `underline` warning is retained below as a separate frontend review item: it was observed in the prior verbose editor test; the latest verification focused on the OTP bridge and did not rerun that editor-specific verbose check.

Result counts

| Evidence category | Current result | |---|---| | Root automated suite (`npm test -- --run`) | **PASS:** 21/21 tests; 3 files | | OTP bridge Node regression suite (`node --test functions/test/otpBridge.cjs`) | **PASS:** 8/8 tests; mocked upstream | | Lint, Node syntax checks, `git diff --check` | **PASS:** all commands exited 0 | | Production build | **PASS, earlier audit only:** exit 0 with a non-blocking large-bundle warning; not rerun after this fix | | Current failures | **0** | | Live integration checks | **6 BLOCKED** | | Other checks without safe execution/ evidence | **5 NOT TESTED** | | Separate frontend warning | **1 REVIEW NEEDED:** duplicate Tiptap underline warning previously observed |

The pre-fix mocked HTTP 503 failure is historical evidence and is not counted as a current failure. Automated test counts above refer to separate test runner executions; they do not represent live service tests.

Verified architecture and test environment

- **Web app:** Vite + React. `src/firebase.js` initializes the Firebase client from Vite environment configuration and exports Firebase Auth. Configuration values were not printed or copied into this report.
- **Authentication UI:** `src/components/auth/LoginPage.jsx` directly uses Firebase email/password creation and login, Google popup login, password reset, Firebase TOTP MFA resolution, and an email OTP HTTP request. The email OTP endpoint is read from `VITE_OTP_WORKER_URL`.
- **App-wide auth state:** `src/context/AuthContext.jsx` maintains a localStorage session and also includes a local account registry path. Its `logout()` clears app context/localStorage but does not call Firebase `signOut()`. No Firebase `onAuthStateChanged()` listener was found in this provider.
- **Notes and folders:** `src/context/NotesContext.jsx` loads and saves notes/folders with per-user-keyed `localStorage` entries and debounced local autosave. The `syncNow()` method writes those same local entries; no Firestore/Storage SDK calls were found in the context or Firebase initialization.
- **Firebase Functions:** `functions/index.js` exports an HTTP `otpBridge`; it forwards requests using `OTP_SERVICE_URL`. The function package declares Node.js 24 and Firebase Admin/Functions dependencies. The function source inspected does not use Admin SDK or Resend.
- **OTP service:** `otp-service.gs` contains Google Apps Script `doPost`/`doGet` logic. It validates Firebase ID tokens through the Identity Toolkit lookup endpoint, sends email through `MailApp`, and stores codes in Script Cache for 300 seconds. The repository also contains a Firebase Web API key literal in setup code; its value is deliberately omitted here.
- **Absent infrastructure:** `firebase.json` contains a Functions codebase only; it has no `emulators` configuration. No `firestore.rules`, `storage.rules`, or Firestore indexes file was found. No Cloudflare Worker implementation was found. The root package has no backend-specific test script; the Functions package has no test script. A checked-in OTP bridge regression test is now present at `functions/test/otpBridge.cjs` and is run directly with Node's built-in test runner.
- **Secrets handling:** `.env` files were not read or printed. No real emails, passwords, OTP codes, tokens, private keys, database records, or external production services were used.

Detailed test matrix

ID	Component	Case	Expected result	Actual result / evidence	Status
T-01	Root automated tests	Run all existing tests	Tests complete without failures	`npm test -- --run`: 3 files passed; 21 tests passed; 0 failed; exit 0	**PASS**	
T-02	AuthContext unit tests	Simulated registration, duplicate registration, local login/logout, guest and profile operations	Local context behavior matches its unit-test expectations	Covered by `authFlowIntegration.test.jsx`; these tests exercise local AuthContext behavior, not Firebase Auth	**PASS**	
T-03	Login UI	Email/password form and UI state	Form controls render and UI states operate	UI component tests pass; Firebase methods are mocked in this suite	**PASS**	
T-04	Email OTP UI	Mocked OTP send and verify flow	Successful mocked response permits the UI flow to complete	`uiComponents.test.jsx` mocks Firebase sign-in and `fetch`; no Worker or Apps Script is contacted	**PASS**	
T-05	Notes local behavior	Seed notes, creation, title update, favorite, tag filtering, document type detection, selection	Local state operations satisfy exercised assertions	Covered by `notesWorkspace.test.jsx`; does not test remote persistence or server-side ownership	**PASS**	
T-06	Firebase client initialization	Initialize client without exposing config values	App initializes with valid project config	Static source confirms Firebase app/Auth initialization is present, but initialization against a verified project configuration was not tested	**NOT TESTED**	
T-07	Production build	Compile frontend	Build exits successfully	Earlier audit: `npm run build` exited 0; 2013 modules transformed. Vite warned the generated JS chunk was about 908 KB (>500 KB threshold). Not rerun after OTP fix	**PASS** (earlier audit)	
T-08	Lint	Check repository	Linter exits successfully	`npm run lint`: exit 0	**PASS**	
T-09	Backend source syntax	Parse Functions JS and Apps Script JS syntax	Both sources parse	`node --check functions/index.js && node --check < otp-service.gs`: exit 0	**PASS**	
T-10	OTP bridge	Allowed-origin OPTIONS preflight	204 and matching allow-origin header	Local handler invocation with mocked request returned 204 and expected localhost CORS header	**PASS**	
T-11	OTP bridge	Reject unsupported HTTP method	405	Local handler invocation returned 405	**PASS**	
T-12	OTP bridge	Reject request missing ID token/action	400 without upstream request	Local handler invocation returned 400; mocked fetch call count remained zero	**PASS**	
T-13	OTP bridge	Forward valid send request	POST forwarded and successful upstream response returned	Mocked upstream received one request; bridge returned 200 with the mocked success body	**PASS**

(mock only) | | T-14 | OTP bridge | Propagate upstream HTTP 503 and handle upstream failures safely | Caller receives a non-2xx status; failure bodies/logs do not expose upstream details | Before fix, mocked HTTP 503 became HTTP 200 with a failure body. After fix, the 8-test Node regression suite passed, covering 503→503, other upstream HTTP failures→502, network/invalid JSON/invalid shape→502, success and valid OTP rejection preservation, and request validation | **PASS** (mocked regression tests; no live call) | | T-15 | Firebase email/password registration and login | Real provider registration, valid login, invalid credential rejection | Firebase returns expected account/session outcomes | No credentials or authorized test project were supplied; existing UI tests mock Firebase. No live request made | **BLOCKED** | | T-16 | Google sign-in | Real OAuth popup and authorized-domain behavior | OAuth completes or fails safely | Requires configured provider, authorized domain, and test account; not exercised | **BLOCKED** | | T-17 | Password reset | Send reset to controlled test mailbox | Firebase accepts request and mailbox receives expected email | No mailbox or project credentials; no email sent | **BLOCKED** | | T-18 | Email OTP provider | Worker HTTP status/body, CORS, timeout, error behavior, send/verify/invalid/expired/retry | Live Worker validates and handles codes safely | Worker source and endpoint configuration are unavailable for safe inspection/testing; no external call was made | **BLOCKED** | | T-19 | Google Apps Script OTP | Token verification, mail delivery, expiration, invalid code, retry limits | Apps Script returns secure and consistent outcomes | Source was statically inspected and syntax-checked. Apps Script runtime, deployment, Firebase token and email permissions were not used | **BLOCKED** (live) | | T-20 | Firebase TOTP MFA | Valid/invalid authenticator code and MFA-required sign-in | Resolver handles valid/invalid challenges safely | UI code contains resolver handling, but there is no MFA test or configured test account; no live challenge was run | **BLOCKED** | | T-21 | Firestore/Storage security rules | Anonymous/authenticated access and user ownership isolation | Rules deny unauthorized cross-user reads/writes | No rules files, Firestore/Storage implementation, or emulator config found. There is nothing available to execute in an emulator | **NOT TESTED** | | T-22 | Notes/folder server persistence and ownership | CRUD across sessions/users/devices and cross-user isolation | Server persists data and enforces ownership | Source uses localStorage only; remote persistence and server-side ownership cannot be tested because they are not implemented in the inspected data path | **NOT TESTED** | | T-23 | Offline/localStorage failure behavior | Quota errors, malformed stored data, cross-account separation | Failures are surfaced and stored data remains isolated | Some catches/logging and offline indicators exist, but these edge cases were not executed in this audit | **NOT TESTED** | | T-24 | Firebase Functions deploy/runtime

| Deployability, IAM, billing plan, configured secrets | Function deploys and is reachable in intended project | No deployment or billing/permissions check was made by design. `firebase.json` configures Functions; no emulator configuration exists | **NOT TESTED** | | T-25 | Tiptap duplicate extension | Initialize editor and observe warning | No duplicate extension warning | Verbose `uiComponents.test.jsx` run passed 8 tests but emitted `[tiptap warn]: Duplicate extension names found: ['underline']` | **REVIEW NEEDED** |

Security and reliability findings

Severity describes the potential concern in the inspected implementation, not an exploitation test. Findings below are static-review observations unless explicitly labeled as reproduced.

| ID | Severity | Finding and evidence | Recommendation | |---|---|---|---| | F-01 | **HIGH** | **OTP guessing is not rate-limited in the Apps Script implementation.** A six-digit value is generated with `Math.random()` (`otp-service.gs:69`), cached for 300 seconds (`:72`), and compared without an attempt counter or lockout (`:93-107`). A caller with a valid Firebase ID token can make repeated guesses during the validity window. | Add per-user/IP send throttling, verification attempt limits and backoff/lockout; generate codes using a cryptographically secure source where supported. Test against a staging account. | | F-02 | **MEDIUM** | **Notes are not backed by server-side authorization or persistence in the inspected app path.** Notes/folders are stored in user-keyed `localStorage` (`src/context/NotesContext.jsx:8-52,260-300`); `syncNow()` writes the same local storage (`:921-934`). User IDs in browser keys are not an ownership boundary. No Firestore/Storage rules or SDK data calls were found. | Clarify local-only behavior or implement authenticated server persistence with tested owner-scoped rules before representing notes as cloud-backed/private across devices. | | F-03 | **MEDIUM** | **App logout does not sign out Firebase.** `AuthContext.logout()` clears only local React state (`src/context/AuthContext.jsx:244-246`); no call to Firebase `signOut()` is present in that provider. Firebase SDK auth may therefore remain signed in after the app shows a logged-out state. | Coordinate Firebase sign-out with app-state clearing and test logout/reload on a staging Firebase account. | | F-04 | **MEDIUM** | **The email OTP step is not applied consistently to Google sign-in.** Email/password login requests email OTP (`src/components/auth/LoginPage.jsx:122-141`), while the non-MFA Google path immediately calls

`loginWithFirebaseUser` after popup success (`:267-271`). Native Firebase MFA is handled separately. | Confirm intended policy. If OTP is required for every provider, enforce it on the Google path too; otherwise document the distinction and verify it is intentional. | | F-05 | **MEDIUM** | **The Functions OTP bridge has no explicit upstream timeout.** The latest source still awaits `fetch` and response parsing without an explicit abort/timeout. The prior HTTP-status handling defect and malformed response handling have been corrected and covered by mocked regression tests; this does not establish deployed behavior. | Add a bounded upstream timeout and test it with a mocked timeout plus a controlled staging service before deployment. | | F-06 | **MEDIUM** | **Functions CORS allow-list contains only localhost origins.** `functions/index.js:35-49` sets `Access-Control-Allow-Origin` only for three localhost URLs. No production origin is configured in the repository. | Before using this bridge from a deployed browser app, set a narrowly scoped, environment-appropriate origin allow-list and test OPTIONS and actual requests from the deployed origin. | | F-07 | **MEDIUM** | **A legacy local authentication path stores user registry/session data in localStorage.** `src/context/AuthContext.jsx:57-70,76-107,127-190` implements client-side account registration/login, and `src/utils/crypto.js:1-7` hashes passwords with SHA-256 and a fixed source-defined salt. This is not a server authentication mechanism and is weaker than Firebase password handling. | Keep production account creation/login exclusively on Firebase Auth; remove or isolate any local credential path from production flows. Use a purpose-built slow password KDF only if maintaining a separate server-side account system. | | F-08 | **LOW** | **Firebase Web API key is embedded as a literal in Apps Script setup source** (`otp-service.gs:22-26`). The value is intentionally not reproduced. Firebase Web API keys are project identifiers, not authorization credentials, but source literals complicate rotation/restriction and can be mistaken for a private secret. | Keep the value in Script Properties or deployment configuration, restrict the key to required APIs where supported, and ensure no private credentials are stored alongside it. | | F-09 | **LOW** | **Apps Script failure responses include exception text** (`otp-service.gs:113-114`). Runtime/provider details may be returned to a caller on unexpected failures. | Return a generic client error and retain useful diagnostics only in access-controlled logs, excluding tokens and OTP values. | | F-10 | **LOW / maintainability** | **Duplicate Tiptap underline extension warning was previously reproduced.** `StarterKit` includes underline by default in the installed package and `RichEditor.jsx:68-76` also registers `Underline` separately. The warning was observed in the earlier verbose component-test output; it was not rechecked by the latest OTP-focused verification. | Re-run the

editor-specific test with verbose warnings and, if still present, disable one of the duplicate registrations; then verify formatting behavior. |

Known historical issues rechecked

- `auth/multi-factor-auth-required`**:** Static code contains a resolver path for Firebase TOTP (`LoginPage.jsx:144-160,267-289`). There is no safe live Firebase account to trigger it; **not verified against Firebase**.
- **OTP Worker error ("Request failed…"):** The frontend validates HTTP success and JSON `success` in `callOtpService` (`LoginPage.jsx:33-80`), but no Worker source or endpoint was available for a live check; **not verified**.
- **Firebase Functions Blaze-plan deployment requirement:** No deployment was attempted and no billing-plan query was made; **not rechecked**. The Functions package has a deploy script, but deployment was expressly out of scope.
- **Duplicate Tiptap** `underline` **warning: Reproduced** by the targeted component test; see F-10.

Blocked and untested items

These require an authorized, isolated staging environment and were not simulated as live integrations:

1. Firebase email/password registration, valid/invalid login, password reset, Google OAuth, and actual Firebase logout.
2. Email OTP delivery, invalid/expired OTP behavior, resend/guess throttling, Worker CORS and timeout/error behavior.
3. Firebase TOTP MFA challenge and invalid/expired code paths.
4. Apps Script deployment/permissions and MailApp delivery. No real email was sent.
5. Firestore/Storage rules and cross-user data isolation. Rule files and emulator config are absent.
6. Cloud Functions deployment, IAM, runtime in the target project, configured `OTP_SERVICE_URL`, and billing status.
7. Offline transitions, localStorage quota exhaustion/corruption, and cross-browser/device data persistence.

Prioritized actions

1. Add OTP rate limits, verification attempt caps, secure randomness, and staging tests.
2. Decide whether Notespace is intentionally local-only or needs backend persistence. Do not claim server-enforced privacy or cloud sync until user-owned data storage and rules are in place and tested.
3. Make app logout call Firebase `signOut()` and verify the app/Firebase session state stays consistent across reloads.
4. Confirm and enforce the intended MFA policy for Google and email/password sign-in paths.
5. Add an explicit timeout to the OTP bridge and configure/test deploy-origin CORS. Upstream error status mapping, safe generic error responses, and response-shape validation are now implemented and covered by local mocked tests; verify them against a controlled staging service before deployment.
6. Separate/disable legacy local credential authentication from production flows; review the fixed-salt SHA-256 credential registry.
7. Remove the duplicate Tiptap underline registration and rerun its UI test.
8. Move the Apps Script Web API key literal to deployment configuration and avoid returning raw exception text.

Safe manual verification plan

Perform only in a dedicated staging Firebase project with test identities and a controlled mailbox:

1. Confirm the Firebase Auth providers and authorized domains in the Firebase console; do not use production accounts.
2. Register/login with a staging email identity; verify invalid credentials, password reset delivery, and logout followed by reload. Confirm Firebase Auth and Notespace UI agree on signed-in state.
3. Test Google OAuth using a staging identity and explicitly verify whether the configured product policy requires the email OTP step after Google login.
4. With a test account, exercise OTP send, correct verification, incorrect code, expiry after the configured lifetime, resend behavior, and repeated wrong attempts. Verify throttling/lockout and ensure logs contain no OTPs or bearer tokens.

5. Exercise TOTP MFA separately with a test account that has MFA enrolled; verify both valid and invalid authenticator codes.
6. If backend notes storage is introduced, run Firebase Rules Emulator tests for unauthenticated access, own-user reads/writes, cross-user denial, malformed data, and delete/restore behavior before any production rollout.
7. Validate deployed Functions CORS preflight, timeout handling, malformed upstream response handling, and upstream 4xx/5xx mapping against a stubbed staging service before connecting the real OTP provider.
8. Verify local-only persistence by testing a clean browser profile and offline/quota failure in a non-production browser profile. Do not treat localStorage key separation as authorization.

Commands executed and exit codes

| Command | Exit | Result | |---|---:|---| | `node --test functions/test/otpBridge.cjs` | 0 | **Latest OTP-specific run:** 8 tests passed, 0 failed; mocked upstream cases only | | `npm test -- --run` | 0 | **Latest root suite:** 3 test files; 21 tests passed, 0 failed | | `npm run lint` | 0 | **Latest run:** ESLint passed | | `node --check functions/index.js && node --check functions/test/otpBridge.cjs` | 0 | **Latest syntax checks:** both files parsed successfully | | `git diff --check` | 0 | **Latest check:** no whitespace errors | | `npm run build` | 0 | **Earlier audit, not rerun after OTP fix:** build succeeded; generated JavaScript bundle warning (~908 KB, above Vite's 500 KB advisory threshold) | | `npm test -- --run src/test/uiComponents.test.jsx --reporter=verbose` | 0 | **Earlier audit:** 1 file; 8 tests passed; duplicate Tiptap warning emitted | | Local Node OTP bridge harness with mocked requests/upstream | 0 | **Earlier audit:** four assertions passed: preflight, method guard, invalid request, mocked success forwarding | | Local Node OTP bridge harness with mocked upstream HTTP 503, before fix | 0 process exit | **Historical behavioral failure:** assertion/behavior showed upstream 503 became HTTP 200 with failure body; corrected and covered by the passing regression suite above | | `node --check functions/index.js && node --check < otp-service.gs` | 0 | **Earlier audit:** Functions and Apps Script syntax checks passed | | Firebase CLI availability/version check | 0 | Earlier audit found CLI present (15.34.0); no emulator configuration found |

Readiness assessment

Not ready to certify as a production backend for cloud notes or verified multi-factor access based on this audit. The latest root suite, targeted OTP bridge mocks, lint, syntax checks, and diff check pass; the production build passed only in the earlier audit and was not rerun after this fix. The OTP status-mapping regression is fixed in the current source and covered by mocks, but no deployed Function or live OTP provider was tested. The repository's note persistence path is local browser storage, server-side ownership rules are absent, and external Firebase/Apps Script integrations were not exercised. Six live integration checks remain blocked and five other checks remain not tested. Address the remaining timeout/auth-state/data-security concerns and perform controlled staging integration tests before making production-backend claims.